

# C2 – Exploiter des référentiels, normes et standards adoptés par le prestataire informatique

*Mise en place de la norme ISO 27001 – Projet M2L (Maison des Ligues de Lorraine)*

Date : 04/05/2026

---

## Documentation officielle

 Norme ISO/IEC 27001:2022 – Systèmes de management de la sécurité de l'information (SMSI)

 Guide ANSSI – Méthode EBIOS Risk Manager :

<https://www.ssi.gouv.fr/entreprise/management-du-risque/la-methode-ebios-risk-manager/>

 Site officiel ISO : <https://www.iso.org/fr/standard/27001>

---

## Présentation

Dans le cadre du projet scolaire fictif M2L (Maison des Ligues de Lorraine), l'objectif était de concevoir une infrastructure informatique clé en main pour une organisation multi-sites hébergeant différentes ligues sportives. Ce projet nécessitait de s'appuyer sur des référentiels reconnus pour garantir un niveau de sécurité adapté aux besoins de l'organisation.

La norme ISO/IEC 27001 a été retenue comme référentiel principal. Elle définit les exigences pour établir, mettre en œuvre, maintenir et améliorer un Système de Management de la Sécurité de l'Information (SMSI). Elle repose sur :

- Une approche par les risques (identification, évaluation, traitement)
- Un ensemble de contrôles de sécurité organisés en annexe A (93 contrôles dans la version 2022)
- Le cycle d'amélioration continue PDCA (Plan – Do – Check – Act)

---

## Contexte du projet M2L

Le projet M2L consiste à fournir une infrastructure réseau et système complète à une maison regroupant plusieurs ligues sportives. Les contraintes identifiées étaient :

- **Confidentialité** : Confidentialité des données des adhérents et des licenciés sportifs
- **Disponibilité** : Disponibilité des services informatiques pour les différentes ligues
- **Intégrité** : Intégrité des données stockées et échangées sur le réseau

Ces trois axes (confidentialité, intégrité, disponibilité) constituent le triptyque CIA, fondement de la norme ISO 27001, ce qui a justifié son adoption comme référentiel de sécurité.

---

## Étapes de mise en œuvre

## 1. Identification du périmètre du SMSI

La première étape a consisté à définir le périmètre d'application de la politique de sécurité. Pour le projet M2L, le périmètre retenu inclut :

- L'infrastructure réseau (switches, routeurs, pare-feu)
- Les serveurs hébergés (serveur de fichiers, serveur d'annuaire Active Directory, serveur web interne)
- Les postes de travail des utilisateurs
- Les accès distants (VPN)

## 2. Analyse des risques

Une analyse des risques simplifiée a été réalisée en s'inspirant de la méthode EBIOS Risk Manager préconisée par l'ANSSI. Cette méthode permet d'identifier les sources de menace, les biens supports et les scénarios de risque. Les principaux risques identifiés pour M2L étaient :

- Accès non autorisé aux données des licenciés (attaque externe, vol d'identifiants)
- Panne du serveur principal (indisponibilité des services)
- Fuite de données confidentielles via des postes non sécurisés
- Compromission du réseau Wi-Fi utilisé par les ligues

## 3. Rédaction de la politique de sécurité de l'information (PSI)

Sur la base de l'analyse des risques, une Politique de Sécurité de l'Information (PSI) a été rédigée sous forme de document Word. Ce document constitue le document fondateur du SMSI et s'adresse à l'ensemble des utilisateurs de l'infrastructure M2L.

La PSI rédigée couvre les domaines suivants :

- Politique de gestion des mots de passe (longueur minimale, complexité, renouvellement)
- Politique de contrôle d'accès (principe du moindre privilège, gestion des comptes AD)
- Politique de sauvegarde (règle 3-2-1 : 3 copies, 2 supports différents, 1 hors site)
- Politique de mise à jour (patch management régulier des systèmes)
- Politique d'utilisation des équipements (charte informatique utilisateur)
- Politique de gestion des incidents de sécurité (signalement, traitement, journalisation)

 *Outil utilisé : Microsoft Word – Rédaction de la PSI sous forme de document structuré avec sommaire, chapitres numérotés et tableau de révisions.*

## 4. Mise en correspondance avec les contrôles ISO 27001 (Annexe A)

Pour chaque mesure de la PSI, une correspondance a été établie avec les contrôles de l'Annexe A de la norme ISO 27001:2022. Cette correspondance a été documentée dans un tableau Excel appelé "Déclaration d'Applicabilité" (Statement of Applicability – SoA).

Exemples de correspondances :

| Mesure PSI                 | Contrôle ISO 27001                       | Applicable |
|----------------------------|------------------------------------------|------------|
| Politique de mots de passe | A.5.17 – Informations d'authentification | Oui        |
| Contrôle d'accès AD        | A.5.15 – Contrôle d'accès                | Oui        |
| Sauvegardes 3-2-1          | A.8.13 – Sauvegarde des informations     | Oui        |

|                       |                                               |     |
|-----------------------|-----------------------------------------------|-----|
| Patch management      | A.8.8 – Gestion des vulnérabilités techniques | Oui |
| Charte informatique   | A.6.2 – Termes et conditions d'embauche       | Oui |
| Gestion des incidents | A.5.26 – Réponse aux incidents de sécurité    | Oui |

---

## Outils utilisés

- **Microsoft Word** : Rédaction de la Politique de Sécurité de l'Information (PSI)
- **Microsoft Excel** : Tableau de la Déclaration d'Applicabilité (SoA) et analyse des risques
- **Norme ISO/IEC 27001:2022** : Référentiel principal de sécurité de l'information
- **EBIOS Risk Manager (ANSSI)** : Méthode d'analyse de risques inspirée des pratiques de l'agence nationale de sécurité des systèmes d'information

---

## Pourquoi la norme ISO 27001 ?

Le choix de la norme ISO 27001 repose sur plusieurs raisons fondamentales dans le contexte du projet M2L :

- **Universalité** : C'est une norme internationale reconnue, applicable à tout type d'organisation quelle que soit sa taille
- **Complétude** : Elle couvre l'ensemble des aspects de la sécurité de l'information (physique, logique, organisationnel, humain)
- **Adaptabilité** : Elle peut s'adapter à l'infrastructure d'une petite organisation comme M2L sans nécessiter une certification complète
- **Complémentarité** : Elle est compatible avec d'autres référentiels (ITIL pour la gestion des services, RGPD pour la protection des données)
- **Rigueur documentaire** : Elle impose une démarche structurée et documentée, essentielle pour un projet clé en main livré à un client

---

## Résultat obtenu

À l'issue de cette démarche, les livrables suivants ont été produits dans le cadre du projet M2L :

- Politique de Sécurité de l'Information (PSI) rédigée en Word, structurée en 6 domaines de sécurité
- Déclaration d'Applicabilité (SoA) en Excel, mettant en correspondance les mesures retenues avec les contrôles ISO 27001
- Tableau d'analyse des risques identifiant les menaces et les mesures de traitement associées

Ces documents constituent la base d'un SMSI opérationnel pour l'organisation M2L, démontrant la capacité à exploiter un référentiel normatif international dans un contexte projet réel.

---

## Présentation des domaines ISO 27001 abordés

- **Sécurité organisationnelle** : Politiques, rôles, responsabilités, gestion des risques
- **Sécurité des personnes** : Sensibilisation, formation, charte utilisateur
- **Sécurité physique** : Contrôle d'accès physique aux salles serveurs
- **Sécurité technologique** : Contrôle d'accès logique, sauvegardes, gestion des vulnérabilités
- **Sécurité des communications** : Protection du réseau Wi-Fi, VPN, cloisonnement des VLANs

 Pour en savoir plus sur la norme : <https://www.iso.org/fr/standard/27001>

 Guide ANSSI sur la sécurité des systèmes d'information : <https://www.ssi.gouv.fr/>